DOCUMENTO DE CÁTEDRA N°14
TEMA: APLICACIONES VERTICALES: AUTOMATIZACIÓN EDILICIA (BMS), TRANSPORTE Y CONTROL DE ACCESO FÍSICO

Apertura: El aire acondicionado que robó 40 millones de tarjetas

En noviembre de 2013, la cadena de tiendas Target sufrió la segunda mayor violación de datos del sector minorista de la historia de Estados Unidos: 40 millones de números de tarjetas de crédito y débito robados. La investigación forense del Secret Service y de la firma Verizon Enterprise reveló el vector de entrada: los atacantes no habían comprometido ningún servidor web ni enviado phishing a ejecutivos. Habían accedido a las redes de Target a través de Fazio Mechanical Services, una empresa tercerizada de mantenimiento de sistemas de climatización (HVAC) que tenía acceso remoto al sistema de gestión del edificio (BMS).

El BMS de Target estaba conectado a la misma red lógica que los terminales de punto de venta. Desde el BMS —un sistema diseñado para controlar temperatura y ventilación, no para almacenar datos de tarjetas— los atacantes pivotearon lateralmente hasta los servidores de procesamiento de pagos. El BMS fue el vector de acceso porque nadie lo había incluido en el modelo de amenazas.

Este caso establece la premisa central de este documento: los sistemas de automatización edilicia, de transporte y de control de acceso físico son infraestructuras OT que en entornos convergidos se comportan exactamente como los sistemas SCADA que ya hemos estudiado —con protocolos sin autenticación, software legacy sin parches y conectividad no controlada a redes IT— pero con la diferencia de que ningún modelo de amenazas clásico de IT los considera.

Ubicación en el Programa: Este Documento N°14 cierra la Unidad 3. Habiendo estudiado las arquitecturas SCADA (Doc. N°9), los DCS (Doc. N°10), el historian y OPC (Doc. N°11), y los protocolos industriales Modbus y DNP3 (Docs. N°12-13), este documento aplica ese marco conceptual a tres sectores que el profesional de Ciberdefensa encontrará en instalaciones gubernamentales y militares: automatización edilicia (BMS), infraestructura de transporte, y control de acceso físico (PACS). La Unidad 4 retomará estos escenarios desde la perspectiva doctrinal de la convergencia IT/OT.

. OBJETIVOS DE APRENDIZAJE

Al finalizar la lectura de este documento, el alumno será capaz de:

- Describir la arquitectura de un Sistema de Gestión de Edificios (BMS) e identificar el protocolo BACnet, sus mecanismos de descubrimiento automático y sus vulnerabilidades estructurales.
- Analizar el modelo de objetos BACnet e identificar qué objetos representan puntos de control de alta consecuencia en una instalación crítica.
- Describir la arquitectura de control de los sistemas de señalización ferroviaria y evaluar el perfil de riesgo de los sistemas CBTC sobre redes IP.
- Identificar las vulnerabilidades del protocolo Wiegand en los Sistemas de Control de Acceso Físico (PACS) y comparar su perfil de seguridad con el protocolo OSDP.
- Evaluar el riesgo de interdependencia entre BMS, PACS y redes IT, y diseñar arquitecturas de segmentación que rompan las cadenas de ataque cruzadas.

1. Sistemas de Gestión de Edificios (BMS)

Los Building Management Systems (BMS) —también denominados Building Automation Systems (BAS) o, en contexto de seguridad, Building Control Systems (BCS)— son infraestructuras de control equivalentes funcionalmente a un SCADA de baja complejidad orientado al confort, la eficiencia energética y la seguridad de edificios. Supervisan y controlan los sistemas mecánicos y eléctricos del edificio: HVAC (Heating, Ventilation and Air Conditioning), iluminación, ascensores, sistemas de extinción de incendios y, en muchas instalaciones modernas, los sistemas de seguridad física.

Desde la perspectiva de la Ciberdefensa, los BMS tienen cuatro características que amplifican su perfil de riesgo:

- **Convergencia sin segmentación:** en la mayoría de las instalaciones existentes, el BMS está conectado a la red IT corporativa para permitir el acceso remoto de los contratistas de mantenimiento y la integración con los sistemas de gestión energética. Esta conectividad, implementada por conveniencia operativa, elimina la separación que protege al BMS de los vectores de ataque IT.
- **Acceso de terceros no controlado:** los contratistas de HVAC, las empresas de mantenimiento de ascensores y los proveedores de servicios energéticos tienen acceso remoto habitual al BMS. Este acceso a menudo se gestiona con credenciales compartidas, VPNs mal configuradas o herramientas de acceso remoto públicas (TeamViewer, VNC). El vector del caso Target: las credenciales del contratista de HVAC eran la llave de entrada a la red de la empresa.
- **Software legacy en controladores y servidores:** los controladores de BMS tienen ciclos de vida de 15-25 años. Sus sistemas operativos embebidos y los servidores de gestión frecuentemente ejecutan versiones

de Windows sin soporte de actualizaciones de seguridad. La prioridad es la disponibilidad del servicio (el edificio debe funcionar 24/7), no la aplicación de parches.

- **Impacto físico directo sobre infraestructura crítica:** un BMS comprometido puede afectar directamente la disponibilidad de servicios que soportan la misión de la organización, sin necesidad de comprometer ninguna máquina IT. En un Data Center militar, apagar el HVAC produce el sobrecalentamiento y parada automática de los servidores en minutos.

2. El Protocolo BACnet: Modelo de Objetos y Perfil de Seguridad

Así como Modbus domina la fábrica y DNP3 domina la red eléctrica, BACnet (Building Automation and Control Networks, ASHRAE 135) domina los edificios. BACnet fue diseñado en 1987 por el comité ASHRAE 135 y es el estándar ISO 16484-5. Opera predominantemente sobre IP (BACnet/IP, puerto UDP 47808), aunque existen variantes serie (MS/TP, sobre RS-485) para instalaciones más pequeñas.

2.1. El Modelo de Objetos BACnet

BACnet organiza los datos de sus dispositivos en un modelo orientado a objetos. Cada punto de control o monitoreo del edificio es un Objeto BACnet con un Object Type específico, un Object Identifier único dentro del dispositivo, y un conjunto de Properties (propiedades) accesibles mediante comandos de lectura o escritura. El siguiente catálogo sistematiza los Object Types de mayor relevancia para la Ciberdefensa:

Object Type	Mapeo físico en edificio	Properties críticas	Impacto de escritura maliciosa
Device Object (obligatorio)	El dispositivo BACnet en sí: controlador de HVAC, panel de iluminación, etc.	Device_ID, Vendor_Name, Model_Name, Firmware_Revision, Object_List.	Reconocimiento: revela fabricante, modelo y firmware para buscar CVEs. El Device Object es el equivalente BACnet del FC43 de Modbus.
Analog Input (AI)	Sensores: temperatura de sala, humedad, CO2, corriente eléctrica.	Present_Value (solo lectura), Out_Of_Service, Reliability.	Escribir Out_Of_Service=TRUE desactiva el sensor sin generar alarma: el sistema reporta el último valor válido aunque la sala esté sobrecalentando.

Object Type	Mapeo físico en edificio	Properties críticas	Impacto de escritura maliciosa
Analog Output (AO)	Actuadores: posición de compuerta de ventilación (0-100%), velocidad de ventilador, válvula de agua fría.	Present_Value (lectura/escritura), Priority_Array, Relinquish_Default.	**Alta consecuencia.** Escribir Present_Value=0 cierra el 100% del flujo de aire frío a una sala de servidores. El sistema obedece: es un comando válido sin autenticación.
Binary Output (BO)	Salidas digitales on/off: encendido/apagado de chiller, arranque de bomba, activación de sistema de extinción.	Present_Value (active/inactive), Priority_Array.	Activar o desactivar equipos de climatización o protección contra incendios. La activación maliciosa del sistema de extinción de CO2 en una sala de servidores puede dañar el hardware.
Analog Value (AV)	Setpoints y parámetros de control: temperatura de consigna, setpoint de presión, umbral de alarma.	Present_Value (lectura/escritura).	El equivalente BACnet de los Holding Registers de Modbus. Modificar el setpoint de temperatura de consigna permite un ataque de degradación gradual sin disparar alarmas.
Schedule Object	Programas horarios: guías de encendido/apagado de HVAC, iluminación por horario de ocupación.	Weekly_Schedule, Exception_Schedule.	Modificar el horario puede desactivar el enfriamiento durante el turno más crítico de operación sin producir ninguna alarma de proceso.

2.2. Vulnerabilidades Estructurales de BACnet

Vulnerabilidad	Mecanismo técnico	Contramedida aplicable
Descubrimiento automático sin autenticación (Who-Is / I-Am)	BACnet/IP define el servicio Who-Is como broadcast UDP al segmento de red. Todo dispositivo BACnet responde con I-Am revelando su Device ID y dirección. No requiere autenticación ni configuración previa.	Segmentación de red en VLAN dedicada. Firewall que bloquee el broadcast UDP 47808 hacia redes no autorizadas. Registro de dispositivos activos y alertas por nuevos I-Am.
WriteProperty sin autenticación	BACnet estándar (sin BACnet Security) no implementa autenticación en el servicio WriteProperty. Cualquier cliente BACnet en la misma red puede escribir en cualquier propiedad del dispositivo, incluyendo setpoints y salidas de control.	BACnet Security (ASHRAE 135-2020): autenticación de mensajes con certificados. Firewall industrial que filtre WriteProperty por IP de origen. Inventario de clientes autorizados.
Ausencia de cifrado en tránsito	Todo el tráfico BACnet/IP se transmite en texto claro sobre UDP. El estado de cada sensor, actuador y setpoint del edificio es visible para cualquier dispositivo en la red.	BACnet/SC (Secure Connect, ASHRAE 135-2020 Adenda bj): encapsula BACnet sobre WebSockets con TLS. Requiere soporte del dispositivo; adopción aún en curso. A 2026, la mayoría de los dispositivos BACnet instalados no soportan BACnet/SC; la migración real depende del reemplazo de hardware, no de actualizaciones de firmware.
Out_Of_Service como método de silenciamiento de sensores	La propiedad Out_Of_Service=TRUE sobre un Analog Input desactiva la actualización del Present_Value desde el sensor físico. El sistema de	Monitoreo del atributo Out_Of_Service de todos los sensores críticos. Alertas automáticas ante cualquier cambio en

Vulnerabilidad	Mecanismo técnico	Contramedida aplicable
	control y el operador siguen viendo el último valor válido, aunque el sensor esté reportando una condición peligrosa.	esta propiedad desde una fuente no autorizada.

⚠ Nota de Ciberdefensa — BACnet Who-Is como herramienta de reconocimiento — el Shodan del edificio

El servicio Who-Is de BACnet es funcionalmente equivalente al FC43 (Read Device Identification) de Modbus: permite al adversario descubrir y fingerprinter todos los dispositivos BACnet de la red con una única consulta broadcast, sin autenticación y sin dejar rastro en la mayoría de los sistemas. Herramientas como BAC0 (Python) o YABE (BACnet Explorer) permiten enviar un broadcast Who-Is y recibir el I-Am de todos los dispositivos en segundos. Los dispositivos revelan su Device ID, vendor name, model name y firmware revision — exactamente la información necesaria para buscar CVEs en la base de datos ICS-CERT. El motor de búsqueda Shodan indexa dispositivos BACnet accesibles desde internet en el puerto UDP 47808. La búsqueda 'port:47808' en Shodan muestra edificios gubernamentales, hospitales y universidades con BACnet expuesto públicamente. La primera acción preventiva de un equipo de Ciberdefensa ante cualquier edificio crítico debe ser verificar que el puerto UDP 47808 no es accesible desde internet.

3. Infraestructura de Transporte: Señalización y Redes Ferroviarias

Los sistemas de transporte son ecosistemas OT móviles y altamente distribuidos. Su característica fundamental, que los diferencia de todos los sistemas estudiados hasta aquí, es que el proceso que controlan involucra directamente la seguridad física de personas en movimiento. Las consecuencias de un fallo del sistema de control no son económicas ni operativas: son inmediatamente sobre la vida humana, con latencias de respuesta de milisegundos y tolerancia cero a errores.

Nota sobre el alcance: El análisis de esta sección se centra exclusivamente en los sistemas ferroviarios como modelo representativo de las infraestructuras OT de transporte, por ser el sector con mayor documentación pública de incidentes de ciberseguridad.

3.1. Señalización y Enclavamiento (Interlocking)

El subsistema más crítico de una red ferroviaria es el Interlocking o sistema de enclavamiento: el conjunto de circuitos y lógica que garantiza que dos trenes no puedan ocupar el mismo tramo de vía simultáneamente (colisión) y que ningún

cambio de vía se active cuando un tren está sobre él (descarrilamiento). Históricamente, estos sistemas eran relés electromecánicos físicamente seguros por diseño. En los sistemas modernos, la lógica de enclavamiento se ejecuta en computadoras de control seguras (Vital Safety Computers) con comunicaciones sobre redes de datos.

Los circuitos de vía —los sensores que detectan la presencia de un tren en un tramo— envían su estado al sistema de enclavamiento, que actualiza el estado de ocupación y determina qué aspectos de señal pueden mostrarse. Si un adversario puede inyectar estados de ocupación falsos en el sistema de enclavamiento —indicando que un tramo libre está ocupado, o viceversa— el sistema puede autorizar movimientos de trenes incompatibles. El margen temporal de error es crítico: el sistema de enclavamiento debe responder ante un cambio de estado de circuito en 200-400 ms.

3.2. PTC (Positive Train Control) y CBTC (Communications-Based Train Control)

Sistema	Arquitectura técnica	Perfil de riesgo OT
PTC (Positive Train Control)	Sistema norteamericano obligatorio desde 2020. Combina GPS embarcado, radio 220 MHz y back-end IP centralizado para detectar condiciones de riesgo y aplicar frenos de emergencia automática. El servidor back-end recibe posiciones GPS de todas las locomotoras en tiempo real.	El back-end IP es un objetivo IT clásico. Un adversario que compromete el servidor PTC puede inyectar posiciones GPS falsas para todas las locomotoras simultáneamente, evitando que el sistema detecte condiciones de colisión. El vector de ataque no requiere acceso físico a ningún tren.
CBTC (Communications-Based Train Control)	Sistema para metros urbanos y trenes de alta densidad. Reemplaza los circuitos de vía físicos por comunicaciones inalámbricas (Wi-Fi 802.11 o radio dedicada) entre los trenes y los controladores de zona en el túnel. Cada tren reporta su posición GPS y velocidad; el	La infraestructura Wi-Fi en los túneles es accesible físicamente. Un adversario puede instalar un access point rogué (punto de acceso no autorizado) en el túnel, interceptar comunicaciones tren-controlador, inyectar posiciones falsas, o ejecutar un DoS que

Sistema	Arquitectura técnica	Perfil de riesgo OT
	controlador de zona gestiona la separación.	desactive la comunicación. La pérdida de comunicación activa la parada de emergencia automática: un DoS paraliza todo el metro.
ATP (Automatic Train Protection)	Subsistema de seguridad funcional que supervisa en tiempo real que cada tren opere dentro de los límites de velocidad y autoridad de movimiento. Si el tren excede el límite, ATP aplica frenos de emergencia automáticamente, independientemente del maquinista.	El ATP es la última barrera de seguridad funcional del ferrocarril, equivalente al SIS de una planta industrial. Su compromiso es análogo al ataque TRITON: eliminar la última barrera automática para que un segundo ataque sobre el enclavamiento produzca daño físico sin respuesta automática.

⚠ Nota de Ciberdefensa — Latencia y Safety en sistemas ferroviarios: el umbral de 400 ms

Los sistemas de enclavamiento ferroviario tienen requisitos de latencia de respuesta del orden de 200-400 ms para la actualización del estado de circuitos de vía. Este umbral es una característica de seguridad funcional (Safety), no simplemente una especificación de rendimiento. Si el sistema de enclavamiento no recibe confirmación del estado de un circuito dentro de ese intervalo, activa automáticamente el estado más restrictivo (ocupado / prohibido). Un adversario que entiende este mecanismo puede ejecutar un ataque de degradación de red —no necesariamente un compromiso del sistema de control— que supere los 400 ms de latencia en las comunicaciones del enclavamiento. El sistema responde activando paradas de emergencia en cascada. Sin comprometer ningún controlador, el adversario paraliza la operación ferroviaria completa de una red metropolitana durante el tiempo que dure la degradación.

4. Sistemas de Control de Acceso Físico (PACS)

Los Physical Access Control Systems (PACS) son la interfaz entre la seguridad lógica y la seguridad física de una instalación. Comprenden: lectores RFID/NFC en cada puerta, cerraduras electromagnéticas, molinetes biométricos, paneles

de control y el software de gestión centralizado. Desde la perspectiva OT, cada lector de acceso es un dispositivo embebido en la red de la instalación, con firmware actualizable (o no), con un canal de comunicación hacia el controlador, y con un protocolo que define cómo se transmiten las credenciales.

4.1. El Protocolo Wiegand: Análisis Técnico

El estándar histórico que comunica el lector de tarjetas (instalado en la puerta) con el controlador de acceso (en el panel central) es el protocolo Wiegand. Desarrollado por John Wiegand en la década de 1980, transmite los bits de la credencial RFID como pulsos eléctricos analógicos sobre dos cables (Data0 y Data1) a 0-5 V. El formato más extendido es el de 26 bits:

Bit 0 (Paridad Par) | Bits 1-8 (Código de Instalación) | Bits 9-24 (Número de Tarjeta) | Bit 25 (Paridad Impar)

Formato estándar Wiegand de 26 bits — transmitido como pulsos eléctricos en texto claro

Ejemplo con Código de Instalación (Facility Code) = 1, Número de Tarjeta = 1:

Bit(s)	Campo	Valor binario	Descripción y vulnerabilidad
0	Paridad par	**1 (Bits 1–12 contienen 1 bit con valor «1» [LSB del FC=1]. Conteo impar → para paridad par se agrega «1»)**	Detección de errores de transmisión, no autenticación del emisor. Cualquier dispositivo que calcule la paridad correcta puede emitir la trama.
1-8	Código de Instalación (Facility Code)	**00000001 (= 1 decimal)**	Identifica la instalación u organización. Con 8 bits, solo 256 valores posibles. Un atacante que conoce el Facility Code de una organización puede clonar tarjetas de cualquier empleado con solo capturar su Card Number.
9-24	Número de Tarjeta (Card Number)	**0000000000000001 (= 1 decimal)**	**Sin cifrado.** Los 16 bits del Card Number se transmiten como pulsos eléctricos en texto claro. Con 16 bits, solo 65.535 valores posibles: un espacio de búsqueda trivialmente exhaustible por un sistema automatizado.

Bit(s)	Campo	Valor binario	Descripción y vulnerabilidad
25	Paridad impar	**0 (Bits 13–24 contienen 1 bit con valor «1» [LSB del CN=1]. Conteo impar → para paridad impar se agrega «0»)**	La trama completa es: 1 00000001 0000000000000001 0. Transmitida en ~4 ms sobre los cables Data0/Data1.

4.2. Vectores de Ataque sobre Wiegand

- **Skimming / Bleeding (captura de credenciales):** el cableado Wiegand entre el lector y el panel controlador frecuentemente pasa por el cielorraso, por canalizaciones comunes, o por la misma sala no clasificada donde está la puerta. Un adversario con acceso físico de minutos puede insertar un dispositivo de interceptación (implante BLE, micro-registrador de señal) que captura los pulsos Wiegand cada vez que un usuario pasa su tarjeta. Los bits capturados son enviados por Bluetooth al adversario a distancia, sin necesidad de tocar la tarjeta del usuario ni el panel controlador.
- **Replay Attack (clonación funcional):** con los 26 bits capturados, el adversario construye un dispositivo emisor (emulador Wiegand, fabricable con componentes electrónicos de bajo costo) que replica exactamente los pulsos de la credencial robada. La cerradura no puede distinguirlo de la tarjeta original: abre. El sistema PACS registra una entrada legítima del titular de la tarjeta clonada.
- **Escalada a red IT:** si la sala detrás de la puerta PACS contiene infraestructura IT (servidores, switches, racks de comunicaciones), la brecha física mediante Wiegand se convierte en acceso directo a la infraestructura lógica sin haber utilizado ningún vector cibernético.

4.3. OSDP: La Alternativa Segura

El reemplazo de Wiegand por OSDP (Open Supervised Device Protocol, ANSI/SIA OSDP-2022) es el estándar moderno para instalaciones que requieren un perfil de seguridad adecuado. La tabla comparativa evidencia por qué la migración es imperativa en instalaciones de Defensa:

Característica	Wiegand (legacy)	OSDP (ANSI/SIA 2022)
Cifrado del canal	No. Las credenciales viajan como pulsos eléctricos en texto claro.	Canal seguro AES-128 entre lector y controlador. Los bits de credencial están cifrados en el cable.

Característica	Wiegand (legacy)	OSDP (ANSI/SIA 2022)
Detección de manipulación del cableado	No. El adversario puede interceptar o inyectar pulsos sin que el controlador lo detecte.	Supervisión bidireccional: el controlador detecta si el cable fue cortado, cortocircuitado o si se conectó un dispositivo intermediario.
Comunicación bidireccional	Unidireccional: el lector solo transmite la credencial; no recibe comandos del controlador.	Bidireccional: el controlador puede actualizar firmware del lector, configurar LEDs y zumbadores, y consultar su estado.
Heartbeat / Safe-fail	No. El controlador no puede detectar si el lector fue desconectado.	Heartbeat configurable: si el controlador no recibe señal del lector en el intervalo definido, bloquea la puerta automáticamente (safe-fail).
Autenticación mutua	No. El lector no verifica que el controlador es legítimo.	Autenticación mutua lector-controlador: impide que un controlador falso obtenga credenciales de un lector legítimo.

> **⚠ Nota de Ciberdefensa — El ataque Wiegand en instalaciones de Defensa: el cielorraso como vector**
>
> En instalaciones de Defensa con clasificación de seguridad, el cielorraso del pasillo adyacente a una zona restringida es frecuentemente accesible sin credenciales de alta clasificación. El cableado Wiegand del lector de la zona restringida puede pasar por ese cielorraso. Un adversario que obtiene acceso físico al pasillo puede, en menos de 10 minutos, insertar un implante de captura Wiegand sobre el cable, retirarse, y esperar a que un usuario autorizado pase su tarjeta. La credencial capturada —Facility Code + Card Number en texto claro— proporciona acceso a la zona clasificada con la identidad del usuario legítimo. El sistema PACS no registra ninguna anomalía. La contramedida obligatoria para cualquier instalación de Defensa es la migración a OSDP con canal seguro AES-128: hace que la captura del cableado no produzca credenciales utilizables.

5. La Paradoja de la Convergencia y la Interdependencia

Los documentos anteriores de la Unidad 3 analizaron sistemas donde la convergencia IT/OT es un riesgo conocido y creciente. Este documento presenta

la paradoja central: los sistemas BMS y PACS —diseñados para la seguridad física del edificio— se convierten, al integrarse con la red IT, en vectores de acceso a los sistemas que deberían proteger. La integración genera dos tipos de cadena de ataque cruzada:

- **Cadena 1: Ciberataque → consecuencia física:** un adversario que compromete el BMS vía red puede desactivar las cerraduras electromagnéticas de un edificio (vinculadas al BMS para apertura automática en emergencias de incendio), abrir puertas de zonas restringidas, o deshabilitar el sistema de extinción. El adversario nunca toca ningún activo IT de alto valor: su herramienta es el sistema de gestión del edificio.
- **Cadena 2: Brecha física → acceso lógico:** una Raspberry Pi conectada al switch de un controlador de iluminación del techo (accesible físicamente sin credenciales IT) proporciona acceso a la red IT si el BMS está en la misma VLAN. Es exactamente el vector del caso Target. El adversario no necesita romper ningún firewall: accede físicamente a un nodo OT que tiene conectividad no controlada hacia IT.

5.1. Arquitectura de Referencia: Segmentación Estricta

La arquitectura de referencia del NIST SP 800-82 Rev. 3 y el modelo de DMZ OT del Documento N°9 de esta cátedra aplican directamente a los sistemas BMS y PACS. Los tres principios de segmentación obligatorios son:

1. **BMS en VLAN dedicada y aislada del IT corporativo:** ningún controlador BACnet debe tener conectividad directa con servidores IT, bases de datos corporativas ni salida a internet. El acceso de sistemas IT a los datos del BMS (consumo energético, estado de equipos) debe realizarse a través de un servidor intermediario en la DMZ OT, igual que el historian SCADA del Documento N°9. El servidor intermediario expone datos de solo lectura hacia IT; ninguna escritura puede originarse desde IT hacia controladores BACnet.
2. **PACS en red físicamente separada del BMS y del IT:** las integraciones BMS-PACS (por ejemplo: la apertura automática de puertas ante alarma de incendio) deben implementarse mediante interfaces controladas unidireccionales. Ningún comando puede originarse desde la red IT hacia los controladores de puertas. Los eventos de acceso (entró quién, cuándo) pueden replicarse al SIEM corporativo, pero en sentido único.
3. **Segmentación del acceso de contratistas:** cualquier tercero con acceso remoto al BMS debe conectarse a través de un servidor de salto (Jump Server) en la DMZ OT, con MFA obligatorio, sesión grabada y acceso limitado exclusivamente a los subsistemas de su responsabilidad. Las credenciales deben ser individuales y rotadas tras cada visita de mantenimiento. El mecanismo es exactamente el descrito en la Sección 7 del Documento N°9 para el acceso remoto a sistemas SCADA.

⚠ Nota de Ciberdefensa — La cadena de ataque más corta: del contratista HVAC a la red IT

La cadena de ataque del caso Target puede reconstruirse paso a paso: (1) el adversario obtiene las credenciales del contratista de HVAC mediante phishing o compromiso de sus sistemas; (2) el contratista tiene acceso VPN al BMS de Target para monitorear consumo energético; (3) el BMS de Target está en la misma red que los terminales de punto de venta; (4) desde el BMS, el adversario realiza movimiento lateral mediante credenciales o exploits del SO hacia los sistemas de pago. En ningún paso de esta cadena el adversario vulnera un control de seguridad IT clásico: atraviesa exclusivamente controles de acceso físico e infraestructura OT. La elección del contratista de HVAC como punto de entrada no fue aleatoria: los contratistas de mantenimiento tienen acceso legítimo y frecuente, sus credenciales son menos monitoreadas, y el BMS que acceden raramente tiene los mismos controles que los servidores corporativos.

6. Actividades de Verificación y Análisis

1. Auditoría del caso Target — diseño de red segmentada: Basándose en la arquitectura del caso Target (descrita en la apertura), diseñe la arquitectura de red alternativa que habría impedido el pivotaje desde el BMS hacia la red de punto de venta. (a) Identifique al menos tres decisiones de diseño del sistema original que permitieron el ataque. (b) Describa la arquitectura revisada indicando: VLANs necesarias, firewalls, flujos de comunicación permitidos vs. bloqueados, y cómo el contratista HVAC accede a los datos que necesita sin llegar a la red de pagos. (c) Aplique el modelo de DMZ OT del Documento N°9 a la integración BMS/IT: ¿qué servidor en la DMZ cumple la función de intermediario?

2. Ataque cinético a Data Center militar vía BMS: Un servidor SCADA en un centro de datos militar controla el sistema de enfriamiento de precisión de la sala de servidores mediante BACnet/IP. El BMS está conectado a la red IT corporativa. (a) Describa la secuencia completa de acciones que un adversario ejecutaría para destruir la disponibilidad de los servidores atacando exclusivamente el BMS. Identifique qué Object Types y Properties BACnet serían los objetivos de cada paso. (b) Liste los indicadores forenses que quedarían en los logs del BMS que un analista podría usar para distinguir un ciberataque de un fallo mecánico. (c) Relacione este escenario con la vulnerabilidad Out_Of_Service de la Sección 2: explique cómo un adversario puede usarla para preparar el ataque cinético sin producir alertas previas.

3. Investigación PACS — Wiegand vs. OSDP en instalación de Defensa: Una instalación militar con 400 puertas de acceso controlado en distintos niveles de clasificación utiliza Wiegand en todas las puertas. (a) Liste al menos tres vulnerabilidades específicas del protocolo Wiegand que OSDP elimina o mitiga, con referencia a la sección del documento que las fundamenta. (b) El auditor detecta que las puertas de la zona de clasificación más alta usan Wiegand y las

de la entrada general ya fueron migradas a OSDP. Argumente por qué la puerta de clasificación más alta es la prioridad de migración, no la entrada general. (c) Proponga un plan de migración a OSDP por fases que priorice por nivel de riesgo y sea viable sin interrumpir operaciones.

4. Caso integrador — instalación militar con BMS + PACS + IT convergidos: Una instalación militar de comando y control presenta la siguiente arquitectura existente: (1) BMS que controla la climatización de la sala de comunicaciones, conectado a la red IT corporativa; (2) lectores Wiegand en todas las puertas de zonas clasificadas; (3) cámaras IP en el perímetro vinculadas al BMS para disparar cierres de puertas ante detección de movimiento. (a) Trace la cadena de ataque completa más corta para que un adversario externo logre acceso físico a la sala de comunicaciones sin comprometer ningún activo IT directamente. Indique el vector de entrada, los pasos de movimiento lateral y el punto de compromiso físico. (b) Diseñe una arquitectura de red revisada que rompa esa cadena, usando los conceptos de DMZ OT (Doc. N°9), segmentación estricta y flujos unidireccionales. (c) De los dos protocolos vulnerables identificados en este documento (BACnet y Wiegand), argumente cuál debería priorizarse para reemplazar primero desde la perspectiva de la tríada AIC.

7. Cierre de Unidad 3 — El ecosistema OT completo

La Unidad 3 construyó, documento a documento, el mapa técnico del entorno OT que el profesional de Ciberdefensa encontrará en instalaciones críticas. El recorrido partió de la arquitectura de referencia de los sistemas SCADA (Doc. N°9) y el DCS (Doc. N°10), estableció la función del historian y el protocolo OPC como interfaz de integración IT/OT (Doc. N°11), y profundizó en los dos protocolos de campo dominantes —Modbus (Doc. N°12) y DNP3 (Doc. N°13)— , ambos diseñados sin seguridad desde su origen. Este documento cerró el ciclo demostrando que la misma herencia de inseguridad estructural se replica en sectores que habitualmente quedan fuera del modelo de amenazas clásico: edificios (BMS/BACnet), transporte ferroviario y control de acceso físico (PACS/Wiegand).

El denominador común de los seis documentos es una premisa que debe orientar la práctica profesional: los sistemas OT no son servidores IT con distinto software. Tienen ciclos de vida de décadas, protocolos sin autenticación y operan procesos cuyo fallo produce consecuencias físicas inmediatas sobre la misión.

La Unidad 4 tomará este mapa técnico y lo analizará desde la perspectiva doctrinal: qué establece la normativa de Defensa sobre la convergencia IT/OT, cómo se articula la gestión del riesgo en entornos híbridos y cuál es el rol específico del oficial de Ciberdefensa en la protección de infraestructuras críticas militares.

8. Glosario Mínimo

Término	Definición
ATP (Automatic Train Protection)	Subsistema de seguridad funcional ferroviario que supervisa en tiempo real que cada tren opere dentro de los límites de velocidad y autoridad de movimiento. Actúa como la última barrera de seguridad (equivalente al SIS industrial), aplicando frenos de emergencia automáticamente si se exceden los límites.
BACnet / BACnet/IP	Building Automation and Control Networks. Estándar ASHRAE 135 / ISO 16484-5 para redes de automatización de edificios. BACnet/IP opera sobre UDP en el puerto 47808. Sin autenticación ni cifrado en la versión base.
BMS (Building Management System)	Sistema de supervisión y control del equipamiento mecánico y eléctrico de un edificio (HVAC, iluminación, ascensores, extinción de incendios). Funcionalmente equivalente a un SCADA de baja complejidad.
CBTC (Communications-Based Train Control)	Sistema de control ferroviario que reemplaza los circuitos de vía físicos por comunicaciones inalámbricas (Wi-Fi o radio dedicada) entre trenes y controladores de zona. Utilizado en metros urbanos.
Enclavamiento (Interlocking)	Subsistema ferroviario que garantiza que dos trenes no puedan ocupar el mismo tramo de vía simultáneamente. Su compromiso tiene consecuencias inmediatas sobre la vida humana.
HVAC	Heating, Ventilation and Air Conditioning. Sistema de climatización del edificio. Controlado vía BACnet desde el BMS. En Data Centers, su fallo o sabotaje produce la parada térmica de los servidores en minutos.
Object Type (BACnet)	Clasificación de los puntos de datos en el modelo BACnet: Device, Analog Input/Output/Value, Binary Input/Output/Value, Schedule. El Analog Output y el Binary Output son los objetos de mayor potencial de impacto físico.

Término	Definición
OSDP (Open Supervised Device Protocol)	Protocolo moderno (ANSI/SIA OSDP-2022) para conectar lectores RFID con controladores de acceso. Reemplaza a Wiegand. Incluye canal seguro AES-128, supervisión bidireccional del cableado y heartbeat con safe-fail.
PACS (Physical Access Control System)	Sistema que gestiona y restringe el acceso físico a instalaciones mediante lectores RFID/NFC, cerraduras electromagnéticas, molinetes biométricos y paneles de control centralizado.
PTC (Positive Train Control)	Sistema ferroviario de seguridad activa que detecta condiciones de riesgo (exceso de velocidad, riesgo de colisión) y aplica frenos de emergencia automáticamente. Back-end basado en GPS e IP.
Vital Safety Computer	Computadora de control segura utilizada en los sistemas modernos de señalización ferroviaria donde se ejecuta la lógica de enclavamiento (interlocking), procesando las comunicaciones de red y reemplazando a los tradicionales relés electromecánicos.
Wiegand	Protocolo de cableado (1980s) para comunicar lectores de tarjetas con controladores PACS. Transmite credenciales como pulsos eléctricos en texto claro, sin cifrado, sin firma y sin detección de manipulación del cableado.

8. Referencias Bibliográficas

Stouffer, K., et al. (2023). Guide to Operational Technology (OT) Security (NIST SP 800-82 Revision 3). NIST. (Sección 2.5: Network Protocols; Cap. 3: ICS Risk Management).

Knapp, E. D., & Langill, J. T. (2015). Industrial Network Security (2da ed.). Syngress. (Capítulo 2: Industrial Control Systems; Capítulo 4: Wireless).

ASHRAE. (2020). ANSI/ASHRAE Standard 135-2020: BACnet — A Data Communication Protocol for Building Automation and Control Networks. Atlanta: ASHRAE.

SIA. (2022). ANSI/SIA OSDP-2022: Open Supervised Device Protocol. Security Industry Association.

Krebs, B. (2014). Target Hackers Broke in Via HVAC Company. KrebsOnSecurity. https://krebsonsecurity.com/2014/02/target-hackers-broke-in-via-hvac-company/

Galloway, B., & Hancke, G. P. (2013). Introduction to Industrial Control Networks. IEEE Communications Surveys & Tutorials, 15(2), 860-880.

Cátedra Tecnología Operativa (2026). Documentos de Cátedra N°9 (SCADA), N°10 (DCS), N°11 (Historian y OPC), N°12 (Modbus) y N°13 (DNP3). FADENA.